ESC RELLINGHAUSEN 06 E. V. · JUGENDABTEILUNG

# PROBETRAINING-APP – IT-DOKUMENTATION

> **System:** Probetraining-App der Jugendabteilung · **Verein:** ESC Rellinghausen 06 e. V.
> **Dokument-Stand:** 04.11.2026 · **Verantwortlich (fachlich):** Sascha, Projektleitung
> **Zielgruppe:** IT-Verantwortlicher, Vorstand, künftige Betreuer der App
> Schritt-für-Schritt-Einrichtung: `docs/deployment.md`.

Diese Dokumentation hält fest, **was** betrieben wird, **warum** es so entschieden wurde, **wo** welche Konten und Daten liegen und **wer** zuständig ist. Abschnitte 6 (Inventar) und 9 (Änderungsprotokoll) werden bei der Einrichtung und bei jeder Änderung fortgeschrieben.

## 1. KURZFASSUNG

| | |
|---|---|
| Zweck | Handy-Web-App für Jugendtrainer: Status der Probetraining-Kinder (max. 6 Trainings) → Antrag → Mitglied → spielberechtigt. DFBnet bleibt führend und wird nicht angebunden. |
| Nutzer | Trainer (Login), Eltern (eigenes Anmeldeformular per QR-Code, **ohne Login**), Verwaltung (Airtable) |
| Bausteine | Cloudflare Worker (App, API, Elternformular), Cloudflare Access (Login), Turnstile (Bot-Check), Workers KV, Airtable (Daten, Automationen) |
| Adressen | `https://probetraining.<APP-DOMAIN>` (Trainer, mit Login) und `https://anmeldung.<APP-DOMAIN>` (Eltern, ohne Login) auf einer **eigenen Vereinsdomain nur für die App** |
| Auswirkung auf esc-06.de | **keine** – keine Änderung an Nameservern, DNS, Website oder E-Mail |
| Eigener Server / Patches | keine (vollständig gemanagte Dienste) |
| Laufende Kosten | Domain ca. 5–15 €/Jahr; Cloudflare 0 €; Airtable 0 € oder ein Team-Platz bei hoher Nutzung |
| Status | entwickelt und getestet, **noch nicht in Betrieb**; Datenschutzfreigabe ausstehend |

## 2. ENTSCHEIDUNG ZUR ADRESSE (ENTSCHEIDUNGSPROTOKOLL)

**Entscheidung (04.11.2026, Projektleitung):** Variante **C – eigene Domain für die App**.

**Ausgangslage:** Cloudflare kann den Worker unter einer eigenen Domain nur betreiben, wenn diese Domain als Zone bei Cloudflare liegt. Im kostenlosen Tarif bedeutet das: Nameserver der gesamten Domain zu Cloudflare. Eine Teil-Einrichtung per CNAME gibt es erst ab Business-Tarif, das Auslagern nur einer Subdomain erst im Enterprise-Tarif.

| Variante | Beschreibung | Bewertung |
|---|---|---|
| A | Nameserver von **esc-06.de** zu Cloudflare, App unter `probetraining.esc-06.de` | verworfen: Eingriff in die gesamte DNS-Verwaltung der Vereinsdomain (Website, E-Mail inkl. SPF/DKIM/DMARC, DNSSEC); Risiko von Mail-Ausfällen; neue Zuständigkeit für die IT |
| B | kostenlose Cloudflare-Adresse `….workers.dev` mit Access | möglich, aber lange, kontogebundene Adresse; späterer Wechsel würde neue Links für alle Trainer bedeuten |
| **C** | **eigene Domain** (z. B. `esc06-jugend.de`), komplett bei Cloudflare | **gewählt:** kein Eingriff in esc-06.de, geringe Kosten, technisch einfach (keine Bestandseinträge), unabhängig vom Betrieb der Vereinsdomain |

| Variante | Beschreibung | Bewertung |
|---|---|---|
| D | Cloudflare for SaaS: `probetraining.esc-06.de` per CNAME auf die Zone aus C | nicht gewählt: komplexer, Zusammenspiel mit Access nicht geprüft; bleibt als spätere Option, falls eine Adresse unter esc-06.de gewünscht wird |

**Folgen der Entscheidung:**

- Die Domain ist ein weiteres Vereins-Asset: Inhaber Verein, automatische Verlängerung, zwei Admins (siehe 6).
- Der IT-Verantwortliche muss nichts umstellen, wird aber informiert und kann Mitadmin werden.
- Ein späterer Wechsel auf D ist ohne Umbau der App möglich (nur zusätzliche Adresse).

## 3. AUFBAU

```
Trainer-Handy (Browser)
   │  HTTPS  https://probetraining.<APP-DOMAIN>
   ▼
Cloudflare Access ── Login per Einmal-Code an Adressen der Gruppe „Trainer“, Sitzung bis 1 Monat
   │  setzt signiertes JWT (Cf-Access-Jwt-Assertion)
   ▼
Cloudflare Worker „esc06-probetraining“ (Custom Domain)
   ├─ liefert die App aus (statische Dateien aus app/)
   ├─ /api/*: prüft JWT, ordnet E-Mail → Mannschaft(en) zu, filtert Daten
   ├─ Workers KV „UNDO“: 24 h die Werte vor „War heute da“ (für Rückgängig)
   │  HTTPS, Airtable Personal Access Token (Worker-Secret)
   ▼
Airtable-Base „Probetraining & Neuanmeldungen“ (appBKLVL4A4mI2QHr)
   └─ Automationen: Antragsmail an Eltern, Info an Verwaltung/Trainer, wöchentliche Löschliste

Eltern-Handy ── QR-Code ──► https://anmeldung.<APP-DOMAIN>   (kein Access, öffentlich)
   ▼
Derselbe Worker: liefert nur das Formular aus (app/anmeldung/), prüft Turnstile-Token und Eingaben,
legt das Kind direkt in Airtable an (Status Probetraining, Zähler 1, Datum heute)
```

| Komponente | Quelle im Repository | Hinweis |
|---|---|---|
| Elternformular | `app/anmeldung/index.html`, `app/anmeldung/config.js` | eigene Seite ohne Build; Einwilligungstext und Turnstile-Websiteschlüssel in `config.js` |
| Trainer-App | `app/index.html`, `app/config.js`, `app/aushang.html` | eine HTML-Datei ohne Build; Abhängigkeiten: Google Fonts, `qrcodejs 1.0.0` (cdnjs) |
| API / Worker | `worker/src/*` | TypeScript, 51 automatisierte Tests (`npm run check`) |
| Konfiguration | `worker/wrangler.jsonc` | Domain, Access-Werte, KV-ID; **keine Geheimnisse** |
| Airtable-Schema | `docs/airtable-schema.md` | alle Tabellen-, Feld- und Automations-IDs |
| Demo / Test | `prototype/`, Testversion (claude.ai), `npm run dev:mock` | nur erfundene Daten |

## 4. SICHERHEIT

| Thema | Umsetzung |
|---|---|
| Anmeldung | Cloudflare Access mit One-time PIN; nur Adressen der Zugriffsgruppe „Trainer“; keine Passwörter beim Verein |
| Prüfung im Worker | JWT vollständig geprüft (RS256-Signatur gegen die Access-Zertifikate, Aussteller, Audience, Ablauf). Der E-Mail-Header allein wird nicht vertraut. Ohne konfigurierte Access-Werte lässt der Worker niemanden rein. |

| Thema | Umsetzung |
|---|---|
| Berechtigung | E-Mail muss in Airtable „Mannschaften → Trainer E-Mail" stehen; jeder Zugriff auf die eigene(n) Mannschaft(en) beschränkt; fremde Datensätze werden wie nicht vorhanden behandelt |
| Schreibregeln | Limit 6, einmal pro Tag, Rückgängig nur am selben Tag – serverseitig; POST von fremden Origins abgelehnt |
| Geheimnisse | Ein Secret: Airtable-Token (nur `data.records:read/write`, nur diese Base) als Worker-Secret. Nichts Geheimes im Repository. |
| Erreichbarkeit | Trainer-App nur `https://probetraining.<APP-DOMAIN>` hinter Access; `workers.dev` und Preview-URLs abgeschaltet |
| Elternformular (öffentlich) | eigene Adresse ohne Login; dort liefert der Worker **nur** das Formular und zwei Endpunkte aus (Mannschaftsliste mit ID+Name, Anmeldung), nie die Trainer-App oder Trainer-API. Schutz: Turnstile-Bot-Check (serverseitig geprüft, ohne Schlüssel keine Anmeldung), strenge Eingabeprüfung, 4-KB-Limit, Origin-Prüfung, Dublettenerkennung; die Antwort enthält nie Daten anderer Kinder |
| Kopfzeilen | `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer` |
| Domain | Inhaber Verein, Zwei-Faktor beim Registrar und bei Cloudflare, DNSSEC empfohlen |
| Logs | nur Fehlercodes, keine Namen/Kontaktdaten |

## 5. DATEN UND DATENSCHUTZ

| Daten | Ort | Zugriff |
|---|---|---|
| Kind (Name, Geburtsdatum), Mannschaft, Elternteil (Name, E-Mail, Telefon), Einwilligung, Zähler/Daten, Status | Airtable (Airtable Inc., USA) | Verwaltung (Airtable), Trainer der eigenen Mannschaft (App, eingeschränkt) |
| In der App beim Trainer | Name, **Jahrgang**, Zähler, letztes Training, Status; Elternname/Telefon **nur** bei erreichtem Limit | Trainer der Mannschaft |
| Rückgängig-Werte | Cloudflare Workers KV, 24 h; nur Datensatz-ID, Zähler, Datum | technisch |
| Elternformular | wird direkt nach Airtable geschrieben, im Worker nicht gespeichert; Turnstile wertet Browsermerkmale für den Bot-Check aus | – |
| Login-Protokoll | Cloudflare Zero Trust (E-Mail, Zeit, IP) | Konto-Admins |
| Trainer-E-Mails | Airtable und Zugriffsgruppe „Trainer" | Konto-Admins |

- **Löschkonzept:** Formel „Löschen fällig" (8 Wochen nach dem 1. Training ohne Beitritt, sofort bei Absage, 14 Tage nach Spielberechtigung); Automation 4 mailt montags die Liste; Löschung von Hand durch die Verwaltung.
- **Offen vor Echtbetrieb:** Zustimmung Vorstand; AV-Verträge mit Airtable und Cloudflare; Datenschutzerklärung ergänzen; Einwilligungstext im Formular vervollständigen; klären, ob auf der App-Domain ein Impressum-/Datenschutz-Link nötig ist. Bis dahin nur Beispieldaten.

## 6. INVENTAR (BEI DER EINRICHTUNG AUSFÜLLEN)

| Ressource | Anbieter | Bezeichnung / ID | Inhaber | Admins (mind. 2) | 2FA | Eingerichtet am |
|---|---|---|---|---|---|---|
| Domain `<APP-DOMAIN>` | *Registrar:* | | ESC Rellinghausen 06 e. V. | | ☐ | |

| Ressource | Anbieter | Bezeichnung / ID | Inhaber | Admins (mind. 2) | 2FA | Eingerichtet am |
|---|---|---|---|---|---|---|
| Cloudflare-Konto | Cloudflare | Konto-ID: | Verein (Vereinsadresse) | | ☐ | |
| Zone `<APP-DOMAIN>` | Cloudflare | Free; DNSSEC ☐ | | | – | |
| Zero Trust | Cloudflare | Team-Domain: `<TEAM>.cloudflareaccess.com` | | | – | |
| Access-Anwendung | Cloudflare | „Probetraining-App" (nur `probetraining.` ), AUD: | | | – | |
| Turnstile-Widget | Cloudflare | „Probetraining-Anmeldung", Websiteschlüssel: | | | – | |
| Zugriffsgruppe | Cloudflare | „Trainer" | | | – | |
| Worker | Cloudflare | `esc06-probetraining` | | | – | |
| KV-Namespace | Cloudflare | `UNDO` , ID: | | | – | |
| Airtable-Konto/Base | Airtable | `appBKLVL4A4mI2QHr` | | | ☐ | bestehend |
| Airtable-Token | Airtable | „Probetraining-Worker", Ablauf/Erneuerung: | | | – | |
| Worker-Secrets | Cloudflare | `AIRTABLE_TOKEN` , `TURNSTILE_SECRET` | | | – | |
| Repository | GitHub | `ESC_Public` | | | ☐ | bestehend |

Zugangsdaten **nicht** in dieses Dokument schreiben, sondern im Passwortspeicher bzw. bei den Vorstandsunterlagen hinterlegen.

## 7. BETRIEB UND ZUSTÄNDIGKEITEN

| Aufgabe | Wie | Zuständig |
|---|---|---|
| Trainer hinzufügen/entfernen | Airtable „Mannschaften" **und** Zugriffsgruppe „Trainer"; beim Entfernen Sitzungen widerrufen | Jugendleitung / Projektleitung |
| App-Updates | `npm run check && npx wrangler deploy` (optional automatisch über GitHub) | Projektleitung |
| Token-Rotation | jährlich und bei Personalwechsel: neuer Token → `wrangler secret put AIRTABLE_TOKEN` → alten löschen | Projektleitung |
| Domain-Verlängerung | automatisch; Rechnung prüfen; Kontaktdaten aktuell halten | Kassierer / Vorstand |
| Admin-Wechsel | neuen Admin einladen, alten entfernen, Inventar + Protokoll aktualisieren | Vorstand |
| Überwachung | Worker-Logs (Fehlercodes), Zero-Trust-Login-Protokoll, Airtable-Kontingent | Projektleitung |
| Datenschutz-Löschung | montags Löschliste abarbeiten | Verwaltung |

**Notfall / App nicht erreichbar:** Domain aktiv und bezahlt? → Cloudflare-Status → Worker-Logs → Airtable-Kontingent.
**Sicherheitsvorfall:** Airtable-Token sofort löschen (App hat dann keinen Datenzugriff), Access-Sitzungen widerrufen, neuen Token erst nach Klärung setzen; Vorstand informieren (Meldepflichten prüfen).

## 8. AUSSTIEG / RÜCKBAU

1. Daten aus Airtable exportieren (CSV) bzw. nach Vorgabe löschen.
2. Worker löschen (`npx wrangler delete`), KV-Namespace und Access-Anwendung löschen.
3. Domain kündigen oder für einen Nachfolger behalten.
4. Airtable-Token löschen. Die Vereinsdomain esc-06.de ist von alldem nicht betroffen.

## 9. ÄNDERUNGSPROTOKOLL

| Datum | Änderung | Durch |
|---|---|---|
| 03.11.2026 | App, Worker, Airtable-Erweiterungen (Limit 6, Formular, Automationen 5–6) entwickelt und getestet; nur Beispieldaten | Projektleitung |
| 04.11.2026 | Entscheidung Variante C (eigene Domain), siehe Abschnitt 2 | Projektleitung |
| 04.11.2026 | Eigenes Elternformular ohne Login (`anmeldung.<APP-DOMAIN>`, Turnstile) statt Airtable-Formular – Grund: Airtable-Formular verlangte im Test eine Anmeldung und lässt sich nicht im Vereinsdesign gestalten | Projektleitung |
| | Domain registriert: | |
| | Cloudflare-Konto, Zone, Access eingerichtet | |
| | Worker veröffentlicht, Abnahme (deployment.md Schritt 6) bestanden | |
| | Datenschutzfreigabe Vorstand | |
| | Formular veröffentlicht, Automationen eingeschaltet, Go-Live | |